

HealthClaimHardened v1

Independent security review of the isolated Groth16 / BN254 ZKP relation

Decision PASS WITH OBSERVATIONS	Scope Circuit, tests, trust boundaries, and adversarial behavior
---	--

Executive result

The relation and adversarial tests support the intended claim predicates for the tested cases. All 13 public-input mutations reject the original Groth16 proof, and changes to each of the 31 private witness fields fail constraint solving. The key observation is external: proofs using identity and order-2 torsion authority points are accepted. The verifier key registry must enforce issuer authorization and the intended subgroup policy. Freshness and replay resistance also require external state.

This is a prototype security analysis, not a production deployment assessment. The circuit, frozen Z6 Core, Gateway, Fabric, IPFS, and networking were not changed.

Repository module: zkp/healthclaimhardened
Analysis date: 2026-10-04
Go 1.25.8 | gnark 0.16.3 | gnark-crypto 0.21.0

1. Scope and architecture

Reviewed the existing circuit.go, circuit_test.go, README.md, SECURITY-TEST-MATRIX.md, deterministic hardened-v1 vector, and Z7 validation results. The isolated module uses Groth16 over BN254, Poseidon2 commitments, EdDSA with MiMC challenge, an 8-level Poseidon2 Merkle path, a four-item diagnosis policy, explicit 64-bit range constraints, lab bounds, coverage checks, policy commitment verification, and a record-index-derived nullifier.

The context commitment binds protocol domain, challenge, recipient, deployment, policy/root versions, policy/root commitments, authority key, nullifier, and claim amount. The relation does not establish that any public root, policy, key, identity, or version is trusted.

Public/private interface

13 public inputs: RegistryRoot, RootVersion, PolicyCommitment, PolicyVersion, ClaimAmount, AuthorityKeyX, AuthorityKeyY, Nullifier, ProtocolDomain, Challenge, RecipientID, DeploymentID, ContextCommitment. **31 private witness values:** diagnosis, lab value, policy ID, coverage ceiling, patient secret, lab minimum/maximum, policy maximum, four covered diagnoses, signature R.X/R.Y/S, eight Merkle siblings, and eight directions.

2. Threat model and trust boundaries

Actor / component	Capability / assumption	Guarantee and boundary
Malicious claimant/prover	Knows and alters private witness; attempts false claims.	Tested false witness mutations fail. Soundness/privacy depend on circuit correctness and Groth16/curve/hash assumptions.
Malicious verifier/client	Substitutes public inputs.	All 13 single-input proof mutations reject. Verifier must compare proof statement against expected request state.
Dishonest authority	Can issue signed false records or expose key.	Signature proves use of supplied key only; honesty, identity, authorization, and status are external.
Untrusted ledger/storage	May disclose metadata, replay data, or return false state.	Path proves membership relative to supplied root only; root/policy/version require trusted registries.
Network attacker	Can modify/replay requests; assumed unable to break primitives.	Statement binding detects changed public inputs. Freshness, transport identity, and replay state are external.
Trusted components	Authority-key registry; root/policy registries; verifier and challenge generator; UsedNullifiers state; Groth16 setup/key custody.	Must enforce issuer/subgroup policy, accepted state/version, expected context, unpredictable fresh challenges, duplicate rejection, and correct circuit/key provenance.

3. Security property and adversarial test matrix

The complete row-by-row test mapping is maintained in SECURITY-TEST-MATRIX.md. The table below summarizes the principal findings. All tests in the Z8 run passed their stated assertions; “accepted” on exceptional keys is an intentional observed circuit behavior and a verifier-boundary requirement.

Attack/property	Test / expected	Observed / conclusion
Authority trust anchor	Self-selected key and altered key; registry must reject unauthorized key.	Self-selected key relation can satisfy; verifier must anchor key to registry.
Identity and subgroup	Identity (0,1) and order-2 torsion authority key.	Both proofs accepted. External key validation must reject identity and enforce intended subgroup membership.
Signature / record integrity	Mutated signature plus private field mutation matrix.	Invalid signature and every one of 31 changed private coordinates rejected.
Merkle membership	Wrong root/path, bad direction, all sibling/direction changes.	Rejected; Boolean directions and authenticated path/root constrain derived record index.
Policy/range	Uncovered diagnosis, lab outside bounds, excessive claim/coverage, negative/overflow.	Rejected. Boundary endpoints and all four covered diagnoses accepted.
Context binding	Challenge, recipient, deployment, domain, versions, root, policy, key, claim, nullifier, digest.	Each of 13 public-input mutations rejects original proof; private inconsistent context also unsatisfied.
Nullifier/replay	Alter nullifier; same proof verified twice; change request with same record.	Wrong nullifier rejected; same proof verifies twice; same record retains nullifier across request context. External used-state required.

Public-input tampering was tested at Groth16 verification, not only by checking circuit satisfiability. Each of the 13 values was changed individually against the same valid proof; every verification rejected.

4. Under-constrainedness analysis

TestPrivateWitnessMutationMatrix altered each of the 31 private witness variables independently: diagnosis, lab value, policy ID, coverage ceiling, patient secret, lab minimum/maximum, policy maximum, four covered diagnoses, three signature coordinates/scalar, eight Merkle siblings, and eight path directions. All 31 mutated witnesses were unsatisfied. Fields are bound by the signed record/commitment, policy commitment and predicates, Merkle root, branch index, or nullifier. This is a deterministic regression check, not a formal proof against coordinated alternatives or cryptographic collisions.

The nullifier test keeps secret/path fixed while changing challenge and recipient: nullifier stays equal while the context commitment changes. This demonstrates separation of record identity and request context. It does not provide replay prevention.

5. Boundary and encoding analysis

Valid endpoints accepted: LabValue = LabMin; LabValue = LabMax; ClaimAmount = CoverageCeiling; CoverageCeiling = PolicyMaxClaim; diagnosis matching each of the four policy entries; zero/small values; maximum 64-bit values. Invalid tests rejected negative values and over-64-bit values for applicable fields. Native context helper tests reject noncanonical field encodings and root/policy versions wider than 64 bits.

6. Nullifier, replay, and freshness

The circuit computes a deterministic Poseidon2 nullifier from patient secret and Merkle direction-derived record index, exposes it publicly, and binds it into context. It has no spent-state. A verifier must issue unpredictable challenges, apply a freshness window, track challenge use, and atomically reject repeated UsedNullifiers. The same valid proof verified twice in tests. Root/policy currency, expiry, and revocation are also external. Nullifier stability assumes registry lifecycle preserves a stable index for the same record; reindexing can change it.

7. External assumptions and limitations

- Groth16 does not establish issuer trust.
- Trusted authority-key registration must validate identity, status, identity-point exclusion, and subgroup membership. Identity and order-2 torsion authority-point proofs were accepted in the observed circuit.
- Registry roots, root versions, policy commitments, and policy versions must be authenticated by trusted state.
- Challenge binding is not wall-clock freshness; challenge issuance and replay/use tracking are external.
- UsedNullifiers storage, expiry, and revocation are not implemented.
- Production proving/verification key ceremony and key custody are not implemented.
- Merkle depth 8 and diagnosis set size 4 are fixed prototype parameters.
- Recipient/deployment/domain numeric IDs need canonical application-level mapping.
- ProtocolDomain = 202610041 is constrained but opaque/date-like. A later circuit version should map a documented stable protocol identifier to a canonical field constant; changing this constant changes the relation and keys.

8. Results and decision

Environment: Ubuntu 24.04.5, kernel 6.17.0-1032-oem, linux/amd64; AMD Ryzen 7 PRO 8840HS (8 cores / 16 threads), 27 GiB RAM; Go 1.25.8; gnark 0.16.3; gnark-crypto 0.21.0. `go mod verify` succeeded. The complete hardened suite passed with an isolated GOCACHE. The relation compiled to 22,021 constraints, 13 public variables, and 31 secret variables. Serialized Groth16 proof size was 164 bytes.

The tests support the intended circuit-level predicates for the fixed v1 relation. The exceptional authority-point acceptance and external freshness/trust/storage obligations are material observations requiring enforcement at the verifier boundary. No circuit redesign was made.

PASS WITH OBSERVATIONS

Test command: GOCACHE=/tmp/healthclaim-hardened-cache go test -count=1 -v ./... (passed). Full findings: zkp/healthclaimhardened/SECURITY-ANALYSIS.md and SECURITY-TEST-MATRIX.md.